Security & Privacy Disclosure, Final Report

Action (com.action.consumerapp)

A hardcoded Firebase production API key and database URL, Huawei HMS Push declared exported and routing EU store-customer notification data through Chinese infrastructure subject to the National Intelligence Law, a full Privacy Sandbox profiling stack (Topics API + Custom Audiences) on a discount retailer app, Facebook SDK (including an unexplained gaming module) initializing before consent, and Emarsys/ML Kit/Firebase all initializing pre-consent, unresolved through 109 days and a 19-day-overdue embargo, with zero reply of any kind – not even automated – across five messages

PUBLIC DISCLOSURE, 17 OCTOBER 2026 — EMBARGO REACHED 28 SEPTEMBER 2026, FIVE FINDINGS REMAIN UNADDRESSED

Target	Actionholding B.V., ’s-Gravenzande, Netherlands (3i Group private equity, ~EUR 11.4B revenue, 2,400+ stores across 12 EU countries)
Package	com.action.consumerapp
Platform	Android, static analysis (24,120 smali classes, 30.2 MB APK)
Initial Disclosure (R1)	2026-06-30 (REF ACTION-2026-R1)
Disclosure / Embargo Date	2026-09-28
Report Published	2026-10-17
Overall Severity	CRITICAL
Findings	5 (1 Critical, 4 High)
Correspondence	5 messages sent by RFI-IRFOS over 109 days (30 June through 12 September 2026). privacy@action.com and dpo@action.com both hard-bounced on the first and only attempt (address not found); press@action.com, copied throughout, accepted every message without a single bounce but also without a single reply of any kind – not even an automated acknowledgment – across four follow-ups
Authorities CC’d	Österreichische Datenschutzbehörde (DSB), Austria; European Data Protection Supervisor (EDPS, edps@edps.europa.eu)

security@rfi-irfos.com • rfi-irfos.com
ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 5

3 Engagement Summary 5

4 Findings 6
- 4.1 C1: Firebase API key and production database URL hardcoded in every distributed copy of the app . . . 6
- 4.2 H1: Huawei HMS Push declared exported, routing EU retail-customer push data through Chinese infrastructure with no identified transfer mechanism . . . 7
- 4.3 H2: Topics API + Custom Audiences: the full Privacy Sandbox advertising-profiling stack on a discount-retailer app . . . 8
- 4.4 H3: Facebook SDK initializes pre-consent via FacebookInitProvider, including an unexplained gaming-services module . . . 9
- 4.5 H4: Emarsys, ML Kit, and Firebase all initialize pre-consent, alongside three BOOT_COMPLETED receivers . . . 10

5 Impact Analysis 10

6 The Complete Chain: Five Messages Across 109 Days, Not One Reply of Any Kind 11

7 Disclosure Timeline & Outcome 11

8 Data Protection — Article by Article 12

9 Regulatory Landscape & Fine Exposure 12

10 Indicators of Compromise 13

11 Residual Risk & Recommendations 13

Executive Summary

Actionholding B.V. ('s-Gravenzande, Netherlands), a 3i Group-backed discount retailer operating 2,400+ stores across 12 EU countries, publishes com.action.consumerapp on Google Play. A static analysis identified five findings, one CRITICAL and four HIGH, spanning a hard-coded production credential, a Chinese push-notification infrastructure dependency, a full advertising-profiling stack, and three separate pre-consent SDK initializations.

A functioning-format Firebase API key and the app's production database URL are hard-coded verbatim in res/values/strings.xml, present in every distributed copy of the app (C1). Huawei HMS Push is declared with android:exported="true", meaning its PushProvider is callable from outside the app, and routes push-notification data for 2,400+ EU retail customers through Huawei Technologies Co. Ltd. infrastructure, a company subject to Article 7 of China's National Intelligence Law, which obliges Chinese organizations and citizens to 'support, assist, and cooperate with national intelligence work'; no Art. 44-49 GDPR transfer mechanism was identified (H1). The manifest declares both the Topics API and Custom Audiences permissions – the full Privacy Sandbox advertising-profiling combination – on an app that already knows its users' purchase behavior, product categories, and price segments, without an identifiable Art. 6(1) legal basis for the resulting behavioral and purchasing-power profiles (H2). The Facebook SDK initializes via a manifest-declared FacebookInitProvider ContentProvider before any consent screen, transmitting purchase-conversion events to Meta Platforms (USA); the binary additionally contains com/facebook/gamingservices, a Facebook module built for gaming platforms, present on a discount-retail app with no discernible gaming context (H3). SAP Emarsys, Google ML Kit, and Firebase all initialize before the consent screen as well, alongside three separate BOOT_COMPLETED receivers that start app components at device startup, with no stated purpose for ML Kit's presence on a retail app (H4).

RFI-IRFOS disclosed these findings on 30 June 2026 to privacy@action.com and dpo@action.com, CC press@action.com, the Austrian DSB, and the EDPS, setting a 90-day embargo of 28 September 2026. Both privacy@action.com and dpo@action.com hard-bounced within the hour (address not found). Four follow-up messages went to press@action.com – the only channel that ever accepted a message – on 17 July, 15 August, 29 August, and 12 September 2026, each restating three direct questions. Not one of the five messages drew any reply: no bounce, but also no automated acknowledgment and no human reply of any kind, from any address, at any point in 109 days. This report publishes 19 days after the embargo deadline, with all five findings unaddressed.

ID	Severity	Title
C1	CRITICAL	Firebase API key and production database URL hard-coded in every distributed copy of the app
H1	HIGH	Huawei HMS Push declared exported, routing EU retail-customer push data through Chinese infrastructure with no identified transfer mechanism
H2	HIGH	Topics API + Custom Audiences: the full Privacy Sandbox advertising-profiling stack on a discount-retailer app

ID	Severity	Title
H3	HIGH	Facebook SDK initializes pre-consent via FacebookInitProvider, including an unexplained gaming-services module
H4	HIGH	Emarsys, ML Kit, and Firebase all initialize pre-consent, alongside three BOOT_COMPLETED receivers

Subject & Operator Context

Actionholding B.V. operates Action, a discount variety retailer with 2,400+ physical stores across 12 EU countries and roughly EUR 11.4 billion in annual revenue, backed by 3i Group plc private equity. The Action mobile app (com.action.consumerapp) serves this store-customer base directly. A retailer of this scale processing EU customer data through third-country push infrastructure and a full advertising-profiling stack raises the stakes of each finding below beyond what the same findings would mean for a smaller operator.

Engagement Summary

RFI-IRFOS sent the initial disclosure on 30 June 2026 to privacy@action.com and dpo@action.com, CC press@action.com, the Austrian DSB, and the EDPS, fixing a 90-day embargo of 28 September 2026. Both privacy@action.com and dpo@action.com hard-bounced within the hour, address not found, and were not used again.

Four follow-up messages went to press@action.com – the only address that ever accepted a message – on 17 July 2026 (17 days), 15 August 2026 (29 days since the previous message), 29 August 2026 (60 days since the original disclosure, with an internal response deadline of 5 September 2026 attached to three restated questions), and 12 September 2026 (74 days since disclosure, noting the 5 September internal deadline had passed with no reply). Each message restated the same three questions verbatim: whether any functioning privacy@ or dpo@ channel exists at Action, whether the Huawei HMS Push transfer to China has an Art. 44-49 safeguard, and whether the Facebook gaming-services module is an intentional integration. Across all five messages and 109 days, press@action.com never bounced but also never returned a reply of any kind – not a human response, not an automated acknowledgment, not even a delivery confirmation beyond successful transmission. This report publishes 19 days after the 28 September 2026 embargo, with no movement on any of the five findings.

Findings

C1: Firebase API key and production database URL hardcoded in every distributed copy of the app

CRITICAL (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N, 8.2) — a functioning Firebase API key and the app's production database URL hard-coded verbatim, extractable from any installed copy of a 2,400-store retailer's app

```
google_api_key:        [REDACTED IN PUBLIC REPORT -- disclosed privately to Action in
    R1]
firebase_database_url: [REDACTED IN PUBLIC REPORT -- disclosed privately to Action in
    R1]

Observed fact vs. inference: the presence of these values in the binary is an observed
     fact.
Whether platform restrictions or Firebase Security Rules mitigate the exposure server-
    side is
the operator's determination under Art. 5(2) accountability, not verifiable from the
    client
binary alone.
```

Impact: res/values/strings.xml hardcodes a functioning-format Google API key and the app's Firebase production database URL, present verbatim in every distributed copy of com.action.consumerapp. Any party extracting the APK – a one-minute operation with apktool – obtains both values directly. The key allows a third party to consume Google services (Maps, Storage, ML Kit) at Action's expense, creating a quota-exhaustion/denial-of-service exposure, and, if the underlying Firebase Security Rules are misconfigured, to access real-time database contents directly. For a retailer operating 2,400+ stores across 12 EU countries, this is a production credential, not a test or staging artifact, sitting in every customer's installed app.

H1: Huawei HMS Push declared exported, routing EU retail-customer push data through Chinese infrastructure with no identified transfer mechanism

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.9) — Huawei's PushProvider is declared android:exported="true", callable from outside the app, and routes push data for 2,400+ EU store customers through infrastructure operated by a company subject to China's National Intelligence Law, with no Art. 44-49 GDPR mechanism identified

```
<provider android:name="com.huawei.hms.support.api.push.PushProvider"
          android:exported="true"
          android:readPermission="com.action.consumerapp.permission.PUSH_PROVIDER"
          android:writePermission="com.action.consumerapp.permission.
    PUSH_WRITE_PROVIDER"/>
<meta-data android:name="com.huawei.hms.client.service.name:push" android:value="push
    :6.13.0.301"/>

Operator: Huawei Technologies Co. Ltd. (Shenzhen, China)
Legal obligation: National Intelligence Law of the People's Republic of China, Art. 7
GDPR Chapter V safeguard (Art. 46): not identified
Processing agreement (Art. 28) for this specific transfer: not identified
```

Impact: The manifest declares com.huawei.hms.support.api.push.PushProvider with android:exported="true", meaning the provider is callable from outside the Action app by any other component on the device, gated only by Action's own read/write permission strings rather than Android's default same-app isolation. Huawei HMS Push routes push-notification infrastructure for this app through Huawei Technologies Co. Ltd. (Shenzhen, China), an entity subject to Article 7 of China's National Intelligence Law, which requires Chinese organizations and citizens to 'support, assist, and cooperate with national intelligence work.' Push-notification data for 2,400+ EU store customers therefore flows through infrastructure carrying a structural state-access obligation. No Art. 44-49 GDPR transfer safeguard – Standard Contractual Clause, adequacy mechanism, or otherwise – was identified for this data flow, and no processing agreement (Art. 28) covering this specific transfer was located.

H2: Topics API + Custom Audiences: the full Privacy Sandbox advertising-profiling stack on a discount-retailer app

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.4) — both halves of Google's Privacy Sandbox profiling stack declared together on an app that already knows purchase behavior, product categories, and price segments, with no identifiable Art. 6(1) legal basis

```
<uses-permission android:name="android.permission.ACCESS_ADSERVICES_TOPICS"/>
<uses-permission android:name="android.permission.ACCESS_ADSERVICES_CUSTOM_AUDIENCE"/>
<uses-permission android:name="android.permission.ACCESS_ADSERVICES_AD_ID"/>
<uses-permission android:name="com.google.android.gms.permission.AD_ID"/>

Also reserved in the manifest (not independently assessed as a live finding):
<uses-permission android:name="android.permission.ACCESS_ADSERVICES_ATTRIBUTION"/>

Art. 6(1) legal basis for Topics + Custom Audiences profiling combination: not
    identified
Art. 35 DPIA for this profiling combination: not identified in available disclosures
```

Impact: The manifest declares ACCESS_ADSERVICES_TOPICS (on-device advertising-interest profiles built from app-usage behavior) together with ACCESS_ADSERVICES_CUSTOM_AUDIENCE (cross-app interest groups for retargeting) – the two permissions that together constitute Google's full Privacy Sandbox profiling stack, plus ACCESS_ADSERVICES_AD_ID and the legacy com.google.android.gms.permission.AD_ID. On a discount-retail app that already has visibility into purchase behavior, product categories, and price segments, this combination is capable of producing detailed behavioral and purchasing-power profiles of EU store customers. No Art. 6(1) GDPR legal basis for this specific profiling combination was identified in Action's available disclosures, and the related ACCESS_ADSERVICES_ATTRIBUTION permission is also reserved in the manifest, indicating the attribution half of the same advertising stack is provisioned for future or partial use.

H3: Facebook SDK initializes pre-consent via FacebookInitProvider, including an unexplained gaming-services module

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.6) — a manifest-declared ContentProvider initializes Facebook App Events before any consent screen, transmitting purchase-conversion data to Meta Platforms (USA), alongside a Facebook gaming-services module with no discernible retail purpose

```
com.facebook.internal.FacebookInitProvider — ContentProvider, auto-initializes pre-
    consent
com/facebook/appevents — conversion tracking on purchase transactions
com/facebook/gamingservices — Facebook Gaming Services SDK module

Observed fact vs. inference: that the FacebookInitProvider ContentProvider initializes
     before
Application.onCreate() is documented Android platform behavior, not an inference about
     Action's
own code. That com/facebook/gamingservices is compiled into the binary is an observed
    fact; its
intended purpose on a discount-retail app with no gaming feature was asked directly (
    Question 3,
follow-ups of 29 August and 12 September 2026) and never answered.
```

Impact: com.facebook.internal.FacebookInitProvider is declared in the manifest as a ContentProvider, which Android instantiates before Application.onCreate() and therefore before any consent screen can render – the same structural pre-consent pattern this program has confirmed in other audited apps. Facebook App Events (com/facebook/appevents) tracks conversion events on purchase transactions and transmits purchasing-behavior and browsing data to Meta Platforms, Inc. (USA) before a user has any opportunity to decline. Separately, the binary contains com/facebook/gamingservices, a Facebook SDK module built specifically for gaming platforms, present on a discount-retail app with no discernible gaming feature or context – its inclusion is unexplained and was not addressed across four direct questions to press@action.com.

H4: Emarsys, ML Kit, and Firebase all initialize pre-consent, alongside three BOOT_COMPLETED receivers

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.0) — three separate SDKs, including an on-device ML framework with no stated retail purpose, all initialize before any consent screen can render, and three BOOT_COMPLETED receivers start app components at device startup

```
com.emarsys.EmarsysSdkInitializer (via androidx.startup) — auto-init, pre-consent
com.google.mlkit.common.internal.MlKitInitProvider — initOrder=99, pre-consent
com.google.firebase.provider.FirebaseInitProvider — initOrder=100, pre-consent
3x android.intent.action.BOOT_COMPLETED receivers

Stated purpose for ML Kit on this retail app in available privacy disclosures: not
    identified
```

Impact: SAP Emarsys (marketing automation, initialized via androidx.startup's EmarsysSdkInitializer), Google ML Kit (com.google.mlkit.common.internal.MlKitInitProvider, initOrder=99), and Firebase (com.google.firebase.provider.FirebaseInitProvider, initOrder=100) all initialize before any consent screen can render, following the same structural pre-consent ContentProvider pattern confirmed elsewhere in this binary (H3). ML Kit's presence on a retail app implies on-device image analysis, text recognition, or behavioral modeling capability; no stated purpose for ML Kit appears in Action's available privacy disclosures. Three separate BOOT_COMPLETED receivers additionally start app components automatically at device startup, independent of any user launching the app.

Impact Analysis

C1 and H1 through H4 share a common thread: each represents a decision Action made about which infrastructure to depend on – Firebase for backend services, Huawei for push delivery, Google's Privacy Sandbox and Facebook and Emarsys for advertising and marketing – without the accompanying transparency or safeguard documentation GDPR requires for each specific choice. H1 is the most structurally serious of the four HIGH findings: it names a specific, identifiable transfer pathway (Huawei HMS Push, Chinese infrastructure, a binding state-access law) with an exported attack surface on top of the transfer question. H2, H3, and H4 compound each other – Privacy Sandbox profiling, Facebook conversion tracking, and Emarsys marketing automation all drawing on the same underlying purchase-behavior data a 2,400-store retailer collects – without a unified Art. 6(1) accounting of which SDK processes what, under what basis. That five messages over 109 days produced not one reply of any kind, not even an automated one, from a retailer of this scale is itself a data point: it suggests press@action.com is not merely slow to respond but is not routing formal regulatory disclosures to anyone positioned to act on them.

The Complete Chain: Five Messages Across 109 Days, Not One Reply of Any Kind

30 June 2026: RFI-IRFOS sends the original disclosure to privacy@action.com and dpo@action.com, CC press@action.com, the Austrian DSB, and the EDPS. Embargo deadline fixed: 28 September 2026. Both privacy@action.com and dpo@action.com hard-bounce within the hour, address not found.

17 July 2026 (17 days): First follow-up to press@action.com, restating all three questions in full. No reply.

15 August 2026 (29 days since the previous message): Second follow-up, same three questions restated. No reply.

29 August 2026 (60 days since the original disclosure): Third follow-up, setting an internal response deadline of 5 September 2026 for the same three questions. No reply.

12 September 2026 (74 days since disclosure): Fourth follow-up, noting the 5 September internal deadline had passed with nothing received. No reply.

28 September 2026: Embargo date reached. Correspondence record: five messages sent by RFI-IRFOS, two hard bounces, zero replies of any kind – human or automated – from any address across the full 109-day period.

17 October 2026: This report publishes, 19 days after embargo. All five findings confirmed unaddressed.

Disclosure Timeline & Outcome

2026-06-30 Initial disclosure sent to privacy@action.com and dpo@action.com, CC press@action.com, DSB, EDPS. Embargo fixed at 2026-09-28. Both direct addresses hard-bounce within the hour.

2026-07-17 Follow-up sent, 17 days total, to press@action.com. No reply.

2026-08-15 Follow-up sent, 46 days total. No reply.

2026-08-29 Follow-up sent, 60 days total, internal response deadline set for 2026-09-05. No reply.

2026-09-12 Follow-up sent, 74 days total, noting the 5 September deadline had passed. No reply.

2026-09-28 Embargo date reached. Correspondence record shows five messages sent, two hard bounces, zero replies of any kind from any address.

2026-10-17 This report published, 19 days after embargo, 109 days after original disclosure. All five findings unaddressed.

Data Protection — Article by Article

Art. 32(1)(b) GDPR – Security of processing: C1's hardcoded production Firebase credential falls short of the technical measures Art. 32(1)(b) requires.

Art. 25 GDPR – Data protection by design and by default: C1 (a production credential with no apparent separation from distribution-safe configuration) implicates Art. 25 directly.

Art. 44-49 GDPR – Third-country transfers; Art. 28 – Processor agreements: H1's Huawei HMS Push routes EU retail-customer push data through Chinese infrastructure subject to a binding state-access law, with no identified Art. 46 safeguard or Art. 28 processing agreement covering this specific flow.

Art. 5(1)(f) GDPR – Integrity and confidentiality: H1's exported PushProvider compounds the transfer question with a device-level exposure surface.

Art. 5(1)(b) GDPR – Purpose limitation; Art. 6(1) – Lawfulness: H2's combined Topics API and Custom Audiences profiling stack lacks an identified legal basis for the specific purpose of behavioral and purchasing-power profiling.

Art. 13 GDPR – Transparency: H2 (profiling purpose), H3 (the Facebook gaming module's purpose), and H4 (ML Kit's purpose) all implicate the transparency obligation to state the specific purpose of each processing activity.

Art. 7 GDPR – Conditions for consent: H3 and H4's pre-consent SDK initializations mean whatever consent Action's app later collects cannot have authorized the processing that already began.

Art. 44-49 GDPR – Third-country transfers: H3's Facebook App Events transmits purchase-conversion data to Meta Platforms (USA) before any consent is recorded.

Regulatory Landscape & Fine Exposure

Actionholding B.V. is registered in 's-Gravenzande, Netherlands, placing it under the jurisdiction of the Dutch Autoriteit Persoonsgegevens as lead supervisory authority; the Austrian DSB and the EDPS were copied throughout this correspondence. As an EU-registered controller processing customer data across 2,400+ stores in 12 EU countries, Action is subject to GDPR's full Article 83 fine structure.

Art. 83(5) GDPR – Maximum fines up to EUR 20,000,000 or 4% of worldwide annual turnover – applies to violations of Art. 5 (principles), Art. 6 (lawfulness), Art. 7 (consent), Art. 13 (transparency), and Art. 44-49 (Chapter V transfers). H1, H2, H3, and H4 each implicate at least one of these articles.

Art. 83(4) GDPR – Maximum fines up to EUR 10,000,000 or 2% of worldwide annual turnover – applies to violations of Art. 25 (data protection by design), Art. 28 (processor agreements), and Art. 32 (security). C1 and H1 implicate this tier.

Given Actionholding's reported ~EUR 11.4 billion annual revenue, the 4% turnover basis for Art. 83(5) materially exceeds the EUR 20,000,000 fixed amount, making the percentage-of-turnover calculation the operative ceiling if any of these findings were to result in an enforcement action.

Indicators of Compromise

All findings derive from static analysis of com.action.consumerapp as published on Google Play, analyzed 2026-06-30 (24,120 smali classes, 30.2 MB APK). No Action servers, accounts, or production infrastructure were probed or accessed.

Residual Risk & Recommendations

C1 – Hardcoded Firebase credentials: rotate the exposed API key and verify Firebase Security Rules independently restrict database access regardless of key exposure; move environment-specific credentials out of version-controlled resource files.

H1 – Huawei HMS Push: document the Art. 44-49 transfer safeguard governing this data flow, or replace Huawei HMS Push with a push provider not subject to Chinese state-access obligations; set android:exported="false" on the PushProvider regardless of the transfer question, since no external caller should need direct access to this component.

H2 – Privacy Sandbox profiling: document the Art. 6(1) legal basis for the combined Topics API and Custom Audiences profiling activity, publish the associated Art. 35 DPIA, and notify the Autoriteit Persoonsgegevens of this configuration if not already done.

H3 – Facebook pre-consent + gaming module: gate FacebookInitProvider behind a confirmed consent decision using Meta's own consent-mode APIs; either document the retail purpose of com/facebook/gamingservices or remove it from the build.

H4 – Emarsys/ML Kit/Firebase pre-consent: apply the same consent-gating remediation to all three initializers; publish the specific purpose of ML Kit's presence in the app.

Process-level improvement: establish a functioning privacy@ or dpo@ channel – both bounced on the only attempt made in this engagement – and ensure press@action.com, or whichever channel remains reachable, routes formal regulatory disclosures to legal, security, or data-protection personnel rather than absorbing them without response.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static analysis of com.action.consumerapp as published on Google Play, analyzed 2026-06-30, using publicly available tools (apktool, jadx, jq). No Action servers, accounts, or production infrastructure were probed or accessed. Technical evidence is archived under chain of custody and will be provided to the Autoriteit Persoonsgegevens on request. Research conducted under GDPR Art. 89 (scientific research exemption), ISO/IEC 29147 (coordinated disclosure standard), and the Austrian Federal Constitutional Law Art. 17 (freedom of research). REF ACTION-2026-R1.